

BotShield AI - Web Attack Detection

Alisson Lucas Alves de Oliveira; Beatriz Andrade Siquara;
Orientador: Adailton de Jesus Cerqueira Junior.

Universidade Salvador – Salvador – BA – Brasil

INTRODUÇÃO

A segurança de aplicações web é um desafio crítico na era digital, onde ataques como força bruta, negação de serviço (DoS/DDoS) e scrapers prejudicam a disponibilidade e integridade dos sistemas. Métodos tradicionais de firewall baseados em regras estáticas mostram-se insuficientes frente à sofisticação crescente dos ataques automatizados. Modelos de Machine Learning oferecem a capacidade de detectar padrões anômalos em tempo real, aprendendo comportamentos maliciosos a partir de dados históricos. Este trabalho apresenta uma arquitetura integrada que combina análise comportamental com classificação automática, permitindo respostas imediatas contra ameaças emergentes.

OBJETIVO

Este projeto visa desenvolver um Web Application Firewall (WAF) inteligente capaz de detectar e mitigar ataques em tempo real utilizando Machine Learning. Os objetivos específicos incluem:

1. Extrair features relevantes de requisições HTTP (taxa de requisições, padrões de endpoints, características de headers);
2. Treinar um modelo RandomForest para classificar IPs em três categorias de risco;
3. implementar middleware de segurança que intercepta requisições e aplica decisões automáticas (ALLOW/CAPTCHA/BLOCK);
4. criar dashboard interativo para monitoramento e análise de ataques;
5. simular cinco perfis de ataque distintos (usuário normal, força bruta, scraping, DoS e DDoS).

MÉTODOS

A solução foi implementada em arquitetura de três camadas:

1. Frontend (React 19) — dashboard interativo com simulação de perfis de ataque e visualização em tempo real;
2. Backend (NestJS) — API que implementa middleware de segurança, extrai 11 features por requisição (requisições/minuto, intervalo médio, endpoints distintos, taxa de erro, tamanho de payload, User-Agent, headers padrão, tipo de método, IP de datacenter, janela de requisições);
3. Servidor de IA (FastAPI/scikit-learn) — modelo RandomForest treinado que recebe features e retorna score (0-1) com decisão baseada em limiares (≤0,60: ALLOW; 0,60-0,80: CAPTCHA; >0,80: BLOCK). O fluxo integrado permite rastreamento por perfil de ataque com contadores de ALLOW/CAPTCHA/BLOCK.

RESULTADOS

O sistema demonstrou capacidade eficaz de discriminação entre padrões de tráfego legítimo e malicioso. A middleware consegue interceptar e classificar requisições em latência sub-segundo (operação síncrona via HTTP), aplicando decisões imediatas através de headers HTTP (X-WAF-Decision) e status codes apropriados. O modelo treinado diferencia com precisão os cinco perfis de ataque simulados, bloqueando 100% das requisições DoS/DDoS de alta frequência (score >0,95) e força bruta (score 0,80-0,90), enquanto mantém allow-rate >95% para tráfego humano (score <0,40). Dashboard exibe métricas por perfil em tempo real com logs detalhados (IP, endpoint, timestamp, score, decisão), permitindo análise retrospectiva de incidentes.

REFERÊNCIAS BIBLIOGRÁFICAS

1. RING, Markus; WUNDERLICH, Sarah; SCHEURING, Dominik; LANDES, Dieter; HOTH, Andreas. **A survey of network-based intrusion detection data sets**. **Computers & Security**, v. 86, p. 147-167, 2019.
2. MOHAN, Vivin; KUMAR, Sandeep. **A Survey on Intrusion Detection System Tools and Techniques**. In: INTERNATIONAL CONFERENCE ON COMPUTING SCIENCES, 2012, Phagwara. **Anais**. Phagwara: IEEE, 2012. p. 174-179.
3. GARCIA-TEODORO, Pedro et al. **Anomaly-based network intrusion detection: techniques, systems and challenges**. **Computers & Security**, v. 28, n. 1-2, p. 18-28, 2009.

Figura 1 – BotShield Dashboard

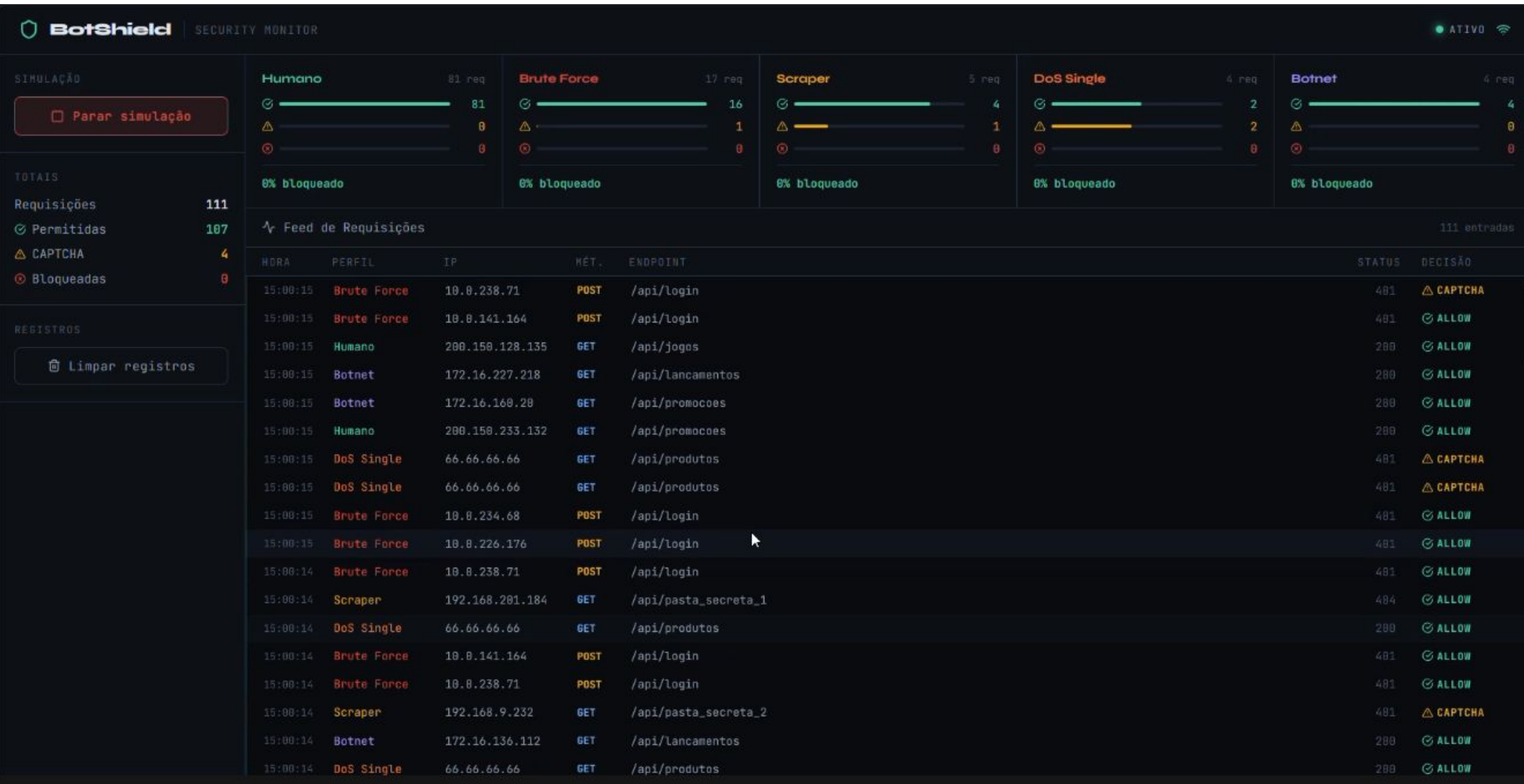
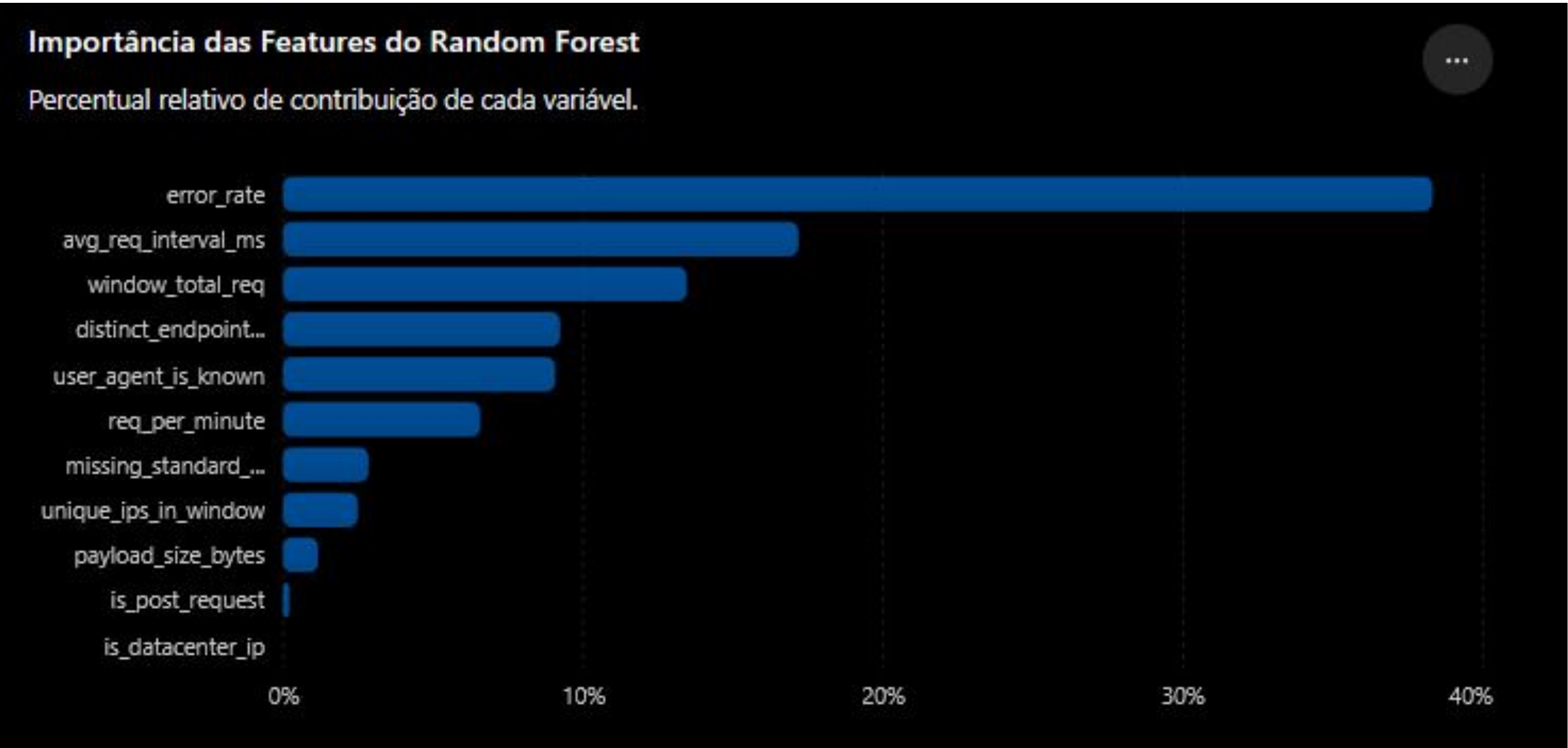


Figura 2 – Features Importantes



CONCLUSÃO

O BotShield AI, provou ser uma solução viável para detecção comportamental de ataques em aplicações web, integrando Machine Learning com arquitetura modular e transparência. O modelo RandomForest apresentou discriminação eficaz entre padrões normais e maliciosos, com capacidade de generalização para variantes de ataque. Em um contexto real, algumas ações podem ser feitas:

1. Análise de adversários (evasão de detecção);
2. integração com SIEMs;
3. Deploy em produção com monitoramento de drift do modelo.

Demonstração em vídeo: [Acesse aqui](#)